

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



BÁO CÁO TIỂU LUẬN CUỐI KỲ
BẢO MẬT TRONG IOT

CẬP NHẬT FIRMWARE AN TOÀN
CHO THIẾT BỊ IOT

Giảng viên hướng dẫn: ThS.Hồ Nhựt Minh

Lớp học phần: 253INT441001

Sinh viên thực hiện: Trần Thị Hà Vy

Mã số sinh viên: 231A010297

TP. HỒ CHÍ MINH - 2026

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN

-----*-----



BÁO CÁO TIỂU LUẬN CUỐI KỲ BẢO MẬT TRONG IOT

CẬP NHẬT FIRMWARE AN TOÀN CHO THIẾT BỊ IOT

Giảng viên hướng dẫn: ThS.Hồ Nhựt Minh

Lớp học phần: 253INT441001

Sinh viên thực hiện: Trần Thị Hà Vy

Mã số sinh viên: 231A010297

TP. HỒ CHÍ MINH - 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	Cập nhật firmware an toàn cho thiết bị IoT
Mã đề tài	20
Hướng đề tài	Hướng C - Firmware và chuỗi boot/update
Sinh viên/Nhóm	Trần Thị Hà Vy - 231A010297
Repo GitHub	https://github.com/hv6z/n20-secure-firmware-update-iot
Bản báo cáo	231A010297_TranThiHaVy_DeTai20_TieuLuan_CuoiKy.docx
Sản phẩm chính	Code demo, manifest, policy, log, ma trận kiểm thử, sơ đồ OTA và bảng rủi ro
Ngày nộp	29/07/2026

Cam kết an toàn và học thuật

Tôi/chúng tôi cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân/nhóm; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

- + Họ tên cam kết: Trần Thị Hà Vy
- + Ngày cam kết: 28/07/2026
- + Chữ ký:


Trần Thị Hà Vy

LỜI MỞ ĐẦU

Sự phát triển nhanh của Internet vạn vật (IoT) làm cho firmware trở thành một thành phần có ảnh hưởng trực tiếp đến độ tin cậy và an toàn của thiết bị. Khi firmware có lỗi hỏng hoặc bị thay đổi trái phép, thiết bị có thể vận hành sai, làm lộ dữ liệu hoặc trở thành điểm xâm nhập vào hệ thống. Vì vậy, cơ chế cập nhật firmware từ xa không chỉ cần thuận tiện mà còn phải bảo đảm gói cập nhật đúng nguồn, không bị sửa đổi và không cho phép quay về phiên bản cũ còn lỗi hỏng.

Đề tài “Cập nhật firmware an toàn cho thiết bị IoT” xây dựng một mô hình mô phỏng cục bộ cho chuỗi phát hành, phân phối, xác minh và kích hoạt firmware. Mô hình kết hợp chữ ký RSA-PSS, mã hóa xác thực AES-GCM, hàm băm SHA-256, kiểm tra target, sequence chống rollback và cơ chế staging - self-test - commit/rollback. Các quyết định ACCEPT hoặc REJECT được thực hiện tại thiết bị, không phụ thuộc vào độ tin cậy tuyệt đối của máy chủ phân phối.

Báo cáo trình bày cơ sở lý thuyết, kiến trúc đề xuất, phương pháp triển khai, năm kịch bản kiểm thử và đánh giá rủi ro theo STRIDE. Kết quả mô phỏng là minh chứng cho logic bảo vệ của prototype trên máy tính; báo cáo không đồng nhất kết quả này với chứng nhận an toàn của một thiết bị thương mại hoặc hệ thống sản xuất.

LỜI CẢM ƠN

Em xin chân thành cảm ơn ThS. Hồ Nhật Minh đã hướng dẫn, góp ý và định hướng để em hoàn thiện đề tài “Cập nhật firmware an toàn cho thiết bị IoT”. Những nhận xét của Thầy giúp em xác định rõ phạm vi an toàn, lựa chọn minh chứng phù hợp và trình bày kết quả theo hướng có thể kiểm tra lại.

Em cũng xin cảm ơn quý Thầy/Cô Khoa Công nghệ thông tin, Trường Đại học Văn Hiến đã trang bị nền tảng kiến thức cần thiết trong quá trình học tập. Các tài liệu chuẩn của IETF, NIST, Espressif và OWASP là nguồn tham khảo quan trọng để em hoàn thiện mô hình và đánh giá các yêu cầu bảo mật.

Do thời gian và điều kiện thiết bị còn hạn chế, báo cáo khó tránh khỏi thiếu sót. Em kính mong nhận được thêm góp ý của Thầy/Cô để tiếp tục cải tiến mô hình, triển khai trên vi điều khiển thật và đánh giá đầy đủ hơn về hiệu năng cũng như khả năng chống chịu trong môi trường thực tế.

MỤC LỤC

Cam kết an toàn và học thuật	i
LỜI MỞ ĐẦU	ii
LỜI CẢM ƠN	iii
MỤC LỤC	iv
DANH MỤC HÌNH ẢNH	vi
DANH MỤC BẢNG BIỂU	vii
DANH MỤC TỪ VIẾT TẮT	ix
CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.2. Vấn đề bảo mật và kịch bản tấn công	1
1.3. Mục tiêu đo được	1
1.4. Đối tượng, phạm vi và giới hạn an toàn	2
1.5. Sản phẩm và đóng góp	2
1.6. Cấu trúc báo cáo	2
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN	3
2.1. Kiến trúc và biên tin cậy của chuỗi cập nhật	3
2.2. Các khái niệm bảo mật được sử dụng	3
2.3. Chuỗi boot/update, phân cứng và bảo vệ khóa	4
2.4. Chuẩn, công cụ và repository tham chiếu	4
2.5. So sánh các giải pháp gần nhất	6
2.6. Tiểu kết Chương 2	6
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ	7
3.1. Phương pháp thực hiện	7
3.2. Mô hình đề xuất	7
3.3. Môi trường, công cụ và dữ liệu	8
3.4. Quy trình và mốc thực hiện	8
3.5. Tiêu chí đánh giá và ngưỡng PASS	9
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ	10
4.1. Chuẩn bị môi trường và chạy mô phỏng	10
4.2. Thành phần sản phẩm và cấu trúc repository	10

4.3. Kịch bản kiểm thử	11
4.4. Kết quả và đối chiếu tiêu chí	11
4.5. Script tổng hợp kết quả	12
4.6. Thảo luận và giới hạn	12
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT	13
5.1. Tài sản và yêu cầu CIA	13
5.2. Phân tích STRIDE gắn với hệ thống	13
5.3. Ma trận rủi ro 5×5 và ưu tiên	14
5.4. Kiểm soát theo rủi ro ưu tiên	14
5.5. Rủi ro còn lại và điều kiện xem xét lại	15
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	16
6.1. Kết luận theo mục tiêu	16
6.2. Hạn chế	16
6.3. Hướng phát triển	16
TÀI LIỆU THAM KHẢO	17
PHỤ LỤC A. PHẦN A – CHECKLIST VÀ PHIẾU TIẾN ĐỘ	18
A.1. Checklist nhanh trước khi viết – Tuần 02	18
A.2. Góp ý và cách xử lý – Tuần 02	18
A.3. Minh chứng đã khai báo – Tuần 02	19
A.4. Thông tin chung của phiếu tiến độ	21
A.5. Checklist tiến độ Tuần 02	21
A.6. Nội dung đã thực hiện trong tuần	22
A.7. Khó khăn/rủi ro đang gặp	23
A.8. Kế hoạch Tuần 03	23
A.9. Tự đánh giá của sinh viên	24
A.10. Tổng hợp tiến độ Tuần 01-06 theo minh chứng thực tế	25
PHỤ LỤC B. REPOSITORY, COMMIT VÀ GÓI NỘP	25
PHỤ LỤC C. CHECKLIST TRƯỚC KHI IN VÀ NỘP	26

DANH MỤC HÌNH ẢNH

Hình 2.1. Kiến trúc và luồng dữ liệu cập nhật OTA; biên tin cậy nằm giữa môi trường phát hành, máy chủ phân phối và thiết bị. Nguồn: tác giả xây dựng.....	3
Hình 3.1. Mô hình cập nhật firmware an toàn do sinh viên đề xuất và số hóa từ bản phác thảo. Nguồn: tác giả xây dựng.....	7
Hình 4.1. Kết quả chạy mô phỏng cục bộ ngày 25/07/2026; dữ liệu hiển thị được trích nguyên từ log do chương trình tạo.....	10

DANH MỤC BẢNG BIỂU

Bảng 1.1. Mục tiêu đo được, đầu ra và cách kiểm chứng.....	1
Bảng 2.1. Các khái niệm bảo mật được sử dụng trong đề tài.....	3
Bảng 2.2. Điểm kiểm tra trong chuỗi boot và cập nhật firmware.....	4
Bảng 2.3. Chuẩn, công cụ và repository tham chiếu.....	4
Bảng 2.4. So sánh các giải pháp liên quan.....	6
Bảng 3.1. Môi trường, công cụ và dữ liệu thử nghiệm.....	8
Bảng 3.2. Quy trình và các mốc thực hiện.....	8
Bảng 3.3. Tiêu chí đánh giá và ngưỡng PASS.....	9
Bảng 4.1. Lệnh tạo môi trường và chạy mô phỏng.....	10
Bảng 4.2. Cấu trúc repository của sản phẩm.....	10
Bảng 4.3. Thành phần sản phẩm và minh chứng.....	11
Bảng 4.4. Các kịch bản kiểm thử.....	11
Bảng 4.5. Kết quả kiểm thử và đối chiếu kỳ vọng.....	11
Bảng 4.6. Trích xuất log của năm ca kiểm thử.....	12
Bảng 5.1. Tài sản và yêu cầu bảo mật CIA.....	13
Bảng 5.2. Phân tích STRIDE cho chuỗi cập nhật OTA.....	13
Bảng 5.3. Ma trận rủi ro 5×5	14
Bảng 5.4. Danh sách và mức ưu tiên rủi ro.....	14
Bảng 5.5. Kiểm soát và rủi ro còn lại.....	14
Bảng 6.1. Kết quả thực hiện theo mục tiêu.....	16
Bảng A.1. Checklist nhanh trước khi viết - Tuần 02.....	18
Bảng A.2. Góp ý và cách xử lý - Tuần 02.....	18
Bảng A.3. Minh chứng đã khai báo - Tuần 02.....	19
Bảng A.4. Thông tin chung của phiếu tiến độ.....	21
Bảng A.5. Checklist tiến độ Tuần 02.....	21
Bảng A.6. Nội dung đã thực hiện trong tuần.....	22
Bảng A.7. Khó khăn và rủi ro đang gặp.....	23
Bảng A.8. Kế hoạch Tuần 03.....	23
Bảng A.9. Tự đánh giá của sinh viên.....	24

Bảng A.10. Tổng hợp tiến độ các tuần theo minh chứng thực tế..... 25

Bảng B.1. Commit dùng để đối chiếu bộ nộp..... 25

Bảng C.1. Checklist trước khi in và nộp..... 26

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích
1	OTA	Over-the-Air – cập nhật firmware qua mạng
2	IoT	Internet of Things – Internet vạn vật
3	AEAD	Authenticated Encryption with Associated Data – mã hóa có xác thực
4	AAD	Associated Authenticated Data – dữ liệu xác thực nhưng không mã hóa
5	RSA-PSS	Cơ chế chữ ký số dựa trên RSA
6	RSA-OAEP	Cơ chế bọc khóa dựa trên RSA
7	AES-GCM	Chế độ mã hóa xác thực Galois/Counter Mode
8	SHA-256	Hàm băm mật mã 256 bit
9	HSM	Hardware Security Module – mô-đun bảo vệ khóa
10	STRIDE	Mô hình phân loại sáu nhóm mối đe dọa

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Firmware điều khiển trực tiếp cảm biến, bộ chấp hành, bộ nhớ và giao tiếp mạng của thiết bị IoT. Khi có lỗi hỏng, cập nhật OTA giúp nhà sản xuất sửa lỗi mà không phải thu hồi thiết bị; ngược lại, một kênh cập nhật thiếu xác minh có thể trở thành đường nạp mã độc. Thiết bị IoT thường phân tán, hoạt động lâu năm và khó bảo trì trực tiếp, nên sai sót trong cơ chế cập nhật có thể tồn tại lâu và ảnh hưởng đồng thời đến nhiều thiết bị.

Đề tài này lựa chọn mô hình mô phỏng cục bộ để làm rõ nguyên tắc cốt lõi: máy chủ OTA chỉ là nơi phân phối, còn thiết bị phải tự xác minh gói trước khi ghi và kích hoạt. Mô hình sử dụng manifest, SHA-256, chữ ký RSA-PSS, mã hóa xác thực AES-256-GCM, ràng buộc target và sequence, vùng staging, self-test và rollback. Cách tiếp cận này phù hợp hướng C – firmware, thiết bị và an toàn vật lý.

1.2. Vấn đề bảo mật và kịch bản tấn công

Kịch bản chính là kẻ tấn công kiểm soát đường truyền hoặc kho phân phối, sau đó thay gói firmware bằng nội dung đã sửa, phát lại một phiên bản cũ còn lỗi hỏng hoặc gửi gói dành cho thiết bị khác. Nếu thiết bị chỉ kiểm tra tên phiên bản hay hash không được ký, kẻ tấn công có thể thay cả firmware và giá trị hash. Nếu thiết bị ghi trực tiếp lên phân vùng đang chạy, một bản cập nhật hợp lệ về mật mã nhưng lỗi chức năng cũng có thể làm thiết bị không khởi động.

Câu hỏi nghiên cứu là: dữ liệu nào cần bí mật, toàn vẹn và xác thực; cơ chế nào phải được kiểm tra trước khi ghi flash; trạng thái nào cần lưu để chống rollback; và bằng chứng nào đủ để người khác chạy lại, quan sát ACCEPT/REJECT và đối chiếu với tiêu chí đã đặt.

1.3. Mục tiêu đo được

Bảng 1.1. Mục tiêu đo được, đầu ra và cách kiểm chứng.

ID	Mục tiêu đo được	Đầu ra	Cách kiểm chứng	Trình bày
MT-01	Nhận diện ≥ 5 rủi ro và biên tin cậy của chuỗi OTA.	STRIDE, risk register, ma trận 5×5 .	Có ID, K, T, điểm và kiểm soát.	Ch. 5
MT-02	Tạo gói có manifest, SHA-256, RSA-PSS và AES-256-GCM.	Code, policy, manifest và chữ ký mẫu.	Chạy demo; xem results/*.json.	Ch. 3–4
MT-03	Mô phỏng target, sequence, staging, self-test và rollback.	Quy trình OTA và trạng thái thiết bị.	TC-04 và TC-05 phải REJECT đúng lý do.	Ch. 3–4
MT-04	Tạo bộ minh chứng tái lập với 5 ca kiểm thử.	README, log, CSV, hình và commit.	5/5 ca trùng kỳ vọng; repo mở được.	Ch. 4

1.4. Đối tượng, phạm vi và giới hạn an toàn

Đối tượng nghiên cứu là chuỗi phát hành–phân phối–xác minh–kích hoạt firmware cho target giả lập `iot-demo-board-v1`. Dữ liệu gồm firmware nhị phân giả lập `v1`, `v2` và `v3_bad`; manifest JSON; khóa công khai demo; policy; log và ma trận kiểm thử. Mô phỏng chạy trên máy cá nhân bằng Python, không kết nối thiết bị thật và không gửi lưu lượng tới hệ thống bên ngoài.

Phạm vi chưa bao gồm bootloader thật, eFuse, Secure Boot, flash encryption, secure element/HSM, HTTPS/mTLS, cập nhật vi sai, mất điện giữa lúc ghi flash, side-channel hoặc benchmark CPU–RAM–năng lượng trên MCU. Các khóa của demo không phải khóa triển khai; repo không chứa token, mật khẩu hay dữ liệu cá nhân thật.

1.5. Sản phẩm và đóng góp

- + Mã mô phỏng `src/code_demo.py` và chính sách `configs/security_policy.json`.
- + Firmware mẫu, manifest, manifest đã ký, khóa công khai demo, log và ma trận 5 ca kiểm thử.
- + Sơ đồ luồng OTA, bảng STRIDE, ma trận rủi ro 5×5 và checklist kiểm soát.
- + Repository công khai <https://github.com/hv6z/n20-secure-firmware-update-iot>, mốc đối chiếu `933dc849b40244fea8a7bd68917f2cc10667cdbf`.

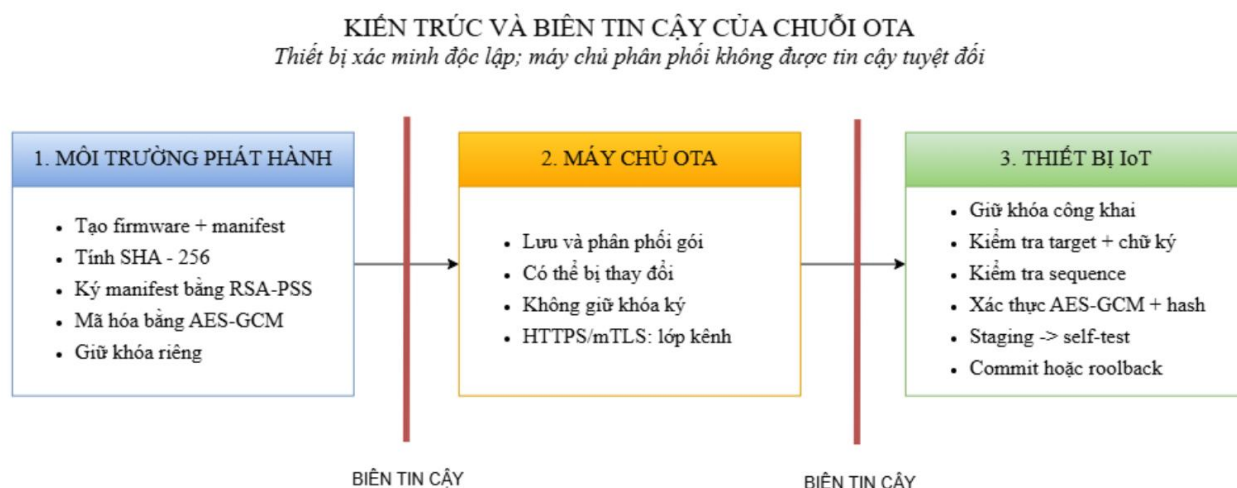
1.6. Cấu trúc báo cáo

Chương 1 xác định vấn đề, mục tiêu và phạm vi. Chương 2 trình bày kiến trúc, cơ chế bảo mật và nguồn được sử dụng. Chương 3 mô tả phương pháp, mô hình, môi trường, quy trình và tiêu chí. Chương 4 trình bày triển khai, cách chạy và kết quả. Chương 5 đánh giá tài sản, STRIDE, rủi ro, kiểm soát và rủi ro còn lại. Chương 6 đối chiếu mục tiêu, nêu hạn chế và hướng phát triển. Các phiếu tiến độ và minh chứng repository được giữ ở phụ lục.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc và biên tin cậy của chuỗi cập nhật

Kiến trúc gồm ba vùng: (1) môi trường phát hành đáng tin cậy giữ khóa riêng và tạo gói; (2) máy chủ OTA/kênh truyền không được tin cậy tuyệt đối; (3) thiết bị giữ root of trust, khóa xác minh và trạng thái sequence. Manifest ký các trường schema, target, version, sequence, size, SHA-256 và thuật toán. Vì máy chủ phân phối có thể bị thay đổi, quyết định cuối cùng luôn do thiết bị đưa ra.



Hình 2.1. Kiến trúc và luồng dữ liệu cập nhật OTA; biên tin cậy nằm giữa môi trường phát hành, máy chủ phân phối và thiết bị. Nguồn: tác giả xây dựng.

Trong Hình 2.1, HTTPS/mTLS nếu được triển khai chỉ bảo vệ kênh. Chữ ký manifest vẫn cần thiết để bảo vệ đầu-cuối khi gói đi qua cache, CDN hoặc máy chủ trung gian. Thiết bị phải fail closed: bất kỳ lỗi cấu trúc, target, chữ ký, sequence, tag AEAD, kích thước hoặc hash nào đều dẫn đến REJECT trước khi commit.

2.2. Các khái niệm bảo mật được sử dụng

Bảng 2.1. Các khái niệm bảo mật được sử dụng trong đề tài.

Khái niệm	Vai trò trong đề tài	Ví dụ trong mô hình
Xác thực nguồn gốc	Chứng minh manifest do bên giữ khóa ký phát hành.	RSA-PSS xác minh `signed_manifest_v2.json`.
Toàn vẹn	Phát hiện nội dung bị sửa.	Chữ ký manifest, AES-GCM tag và SHA-256 firmware.
Bí mật	Giảm lộ nội dung firmware khi phân phối.	Payload AES-256-GCM; khóa AES bọc RSA-OAEP.
Chống rollback	Không cho cài bản cũ dù chữ ký còn hợp lệ.	`sequence` mới phải lớn hơn trạng thái đã lưu.
Đúng target	Ngăn cài nhầm firmware cho	`target` đã ký phải bằng `iot-demo-board`.

Khái niệm	Vai trò trong đề tài	Ví dụ trong mô hình
	model khác.	v1`.
Khả dụng/phục hồi	Không commit bản không hoạt động.	Staging → self-test → commit; lỗi thì rollback.

2.3. Chuỗi boot/update, phần cứng và bảo vệ khóa

Trong prototype, khóa riêng nhà phát hành chỉ tồn tại trong lúc tạo gói; repo chỉ lưu khóa công khai demo. Khi triển khai thật, khóa ký nên ở HSM và có quy trình phân quyền, xoay vòng, thu hồi. Phía thiết bị, khóa công khai và bộ đếm chống rollback cần được neo vào vùng chống sửa như eFuse hoặc secure element; bootloader phải xác minh ảnh trước khi chuyển quyền điều khiển.

Bảng 2.2. Điểm kiểm tra trong chuỗi boot và cập nhật firmware.

Điểm kiểm tra	Dữ liệu	Kiểm soát	Nếu thất bại
Trước tải/parse	Kích thước, schema	Giới hạn 4 MiB; trường bắt buộc	REJECT
Trước giải mã	Target, chữ ký, sequence	RSA-PSS; target đã ký; sequence tăng	REJECT
Sau giải mã	Tag, size, SHA-256	AES-GCM; đối chiếu metadata	REJECT
Sau ghi staging	Khả năng hoạt động	Self-test	Rollback
Khi boot	Ảnh đang kích hoạt	Secure Boot/boot verification (đề xuất)	Boot ảnh dự phòng

2.4. Chuẩn, công cụ và repository tham chiếu

Bảng 2.3. Chuẩn, công cụ và repository tham chiếu.

STT	Nguồn	URL	Phản sử dụng	Truy cập
1	IETF RFC 9019	https://datatracker.ietf.org/doc/html/rfc9019	Kiến trúc cập nhật firmware IoT	28/07/2026
2	IETF RFC 9124	https://datatracker.ietf.org/doc/html/rfc9124	Manifest và điều kiện xử lý	28/07/2026
3	NIST SP 800-193	https://csrc.nist.gov/pubs/sp/800/193/final	Bảo vệ, phát hiện, phục hồi firmware	28/07/2026

STT	Nguồn	URL	Phân sử dụng	Truy cập
4	RFC 8017	https://datatracker.ietf.org/doc/html/rfc8017	RSA-PSS và RSA-OAEP	28/07/2026
5	NIST SP 800-38D	https://csrc.nist.gov/pubs/sp/800/38/d/final	AES-GCM và yêu cầu IV/nonce	28/07/2026
6	ESP-IDF OTA	https://docs.espressif.com/projects/esp-idf/en/v5.4.2/esp32/api-reference/system/ota.html	Phân vùng OTA, rollback	28/07/2026
7	OWASP IoT ISVS	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Yêu cầu cập nhật và bảo vệ khóa	28/07/2026
8	Repo đề tài	https://github.com/hv6z/n20-secure-firmware-update-iot	Code, cấu hình, log và sản phẩm	28/07/2026

2.5. So sánh các giải pháp gần nhất

Bảng 2.4. So sánh các giải pháp liên quan.

Giải pháp/nguồn	Mục tiêu & phương pháp	Ưu điểm	Giới hạn/kế thừa
IETF SUIF (RFC 9019/9124)	Kiến trúc và manifest cập nhật cho thiết bị hạn chế.	Tách vai trò; điều kiện rõ; hướng đầu-cuối.	Prototype kế thừa manifest và điều kiện; chưa mã hóa CBOR/COSE.
ESP-IDF OTA	Cập nhật qua phân vùng OTA, xác nhận ảnh và rollback.	Gần triển khai ESP32; có A/B và bootloader.	Báo cáo kế thừa staging/rollback; chưa chạy trên ESP32.
NIST SP 800-193	Khả năng phục hồi firmware: protect–detect–recover.	Nhấn mạnh phục hồi, root of trust.	Kế thừa self-test/rollback; chưa có phần cứng root of trust.

2.6. Tiểu kết Chương 2

Cơ sở lý thuyết cho thấy một cập nhật an toàn không thể chỉ dựa vào mã hóa hoặc hash. Cần kết hợp xác thực nguồn, toàn vẹn, chống rollback, ràng buộc target và phục hồi. Chương 3 chuyển các yêu cầu này thành mô hình cục bộ, quy trình thực hiện và tiêu chí PASS có thể kiểm tra.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

1. Khảo sát yêu cầu: đọc RFC 9019/9124, NIST SP 800-193, tài liệu ESP-IDF và OWASP; đầu ra là danh sách tài sản, biên tin cậy và kiểm soát.
2. Thiết kế: xác định manifest, thuật toán, thứ tự xác minh và trạng thái thiết bị; đầu ra là policy, sơ đồ và bảng checkpoint.
3. Xây dựng lab cục bộ: tạo firmware giả lập, gói ký/mã hóa và thiết bị xác minh bằng Python; đầu ra là code và dữ liệu mẫu.
4. Kiểm thử theo mối đe dọa: tạo một ca hợp lệ và bốn ca lỗi/tấn công; đầu ra là log và CSV.
5. Đánh giá: so sánh actual với expected, lập STRIDE và ma trận 5×5; đầu ra là kết luận theo MT-01...MT-04.

3.2. Mô hình đề xuất



Hình 3.1. Mô hình cập nhật firmware an toàn do sinh viên đề xuất và số hóa từ bản phác thảo. Nguồn: tác giả xây dựng.

Thiết kế đặt các phép kiểm tra rẻ và không làm thay đổi trạng thái trước: cấu trúc, kích thước, target, chữ ký và sequence. Chỉ sau đó thiết bị mới giải bọc khóa, xác thực/giải mã payload, đối chiếu size và hash. Firmware được ghi vào staging, không ghi đè bản đang chạy; commit chỉ xảy ra sau self-test. Thứ tự này giảm nguy cơ tiêu tốn tài nguyên cho gói sai và tránh mất khả năng phục hồi.

3.3. Môi trường, công cụ và dữ liệu

Bảng 3.1. Môi trường, công cụ và dữ liệu thử nghiệm.

Thành phần	Phiên bản/giá trị	Vai trò	Nguồn dữ liệu
Hệ điều hành	Windows, kiểm tra 25/07/2026	Môi trường chạy cục bộ	Máy cá nhân
Python	3.12.13 khi rà soát; README yêu cầu 3.11+	Chạy prototype và test	Python runtime
cryptography	Repo quy định $\geq 44, < 47$	RSA-PSS/OAEP, AES-GCM	requirements.txt
Target	iot-demo-board-v1	Ràng buộc đúng model	security_policy.json
Firmware	v1, v2, v3_bad	Hợp lệ, rollback, lỗi self-test	data/ – dữ liệu giả lập
Git/GitHub	main @ a8febb2	Quản lý và đối chiếu minh chứng	https://github.com/hv6z/n20-secure-firmware-update-iot

3.4. Quy trình và mốc thực hiện

Bảng 3.2. Quy trình và các mốc thực hiện.

Bước	Mốc/ngày	Công việc	Sản phẩm/minh chứng
1	14/07/2026	Khởi tạo repo, policy và firmware mẫu.	README, configs/, data/
2	16/07/2026	Hoàn thiện manifest, mã demo và sơ đồ.	src/, results/*.json, hình
3	18/07/2026	Chạy 5 ca, dọn khóa/file tạm, cập nhật báo cáo.	log, CSV, lịch sử commit
4	23/07/2026	Điền nội dung vào form tiểu luận.	Bản Word tích lũy
5	28/07/2026	Đối chiếu phiếu hướng dẫn, chạy lại 5 ca và hoàn thiện bản in.	5/5 PASS; DOCX/PDF cuối

3.5. Tiêu chí đánh giá và ngưỡng PASS

Bảng 3.3. Tiêu chí đánh giá và ngưỡng PASS.

Tiêu chí	Ngưỡng PASS	Bằng chứng
Đúng quyết định	TC-01 ACCEPT; TC-02...TC-05 REJECT đúng lớp kiểm soát.	test_matrix.csv và log
Độ bao phủ tình huống	Có ≥ 5 ca: hợp lệ, sai chữ ký, sai ciphertext, rollback, self-test lỗi.	Bảng 4.2
Khả năng tái lập	Cài requirements và chạy một lệnh; kết thúc SUMMARY fail=0.	README và Hình 4.1
An toàn repository	Không có khóa riêng triển khai, token, mật khẩu hay file tạm.	.gitignore, README_KEYS, cây repo
Liên kết mục tiêu	MT-01...MT-04 đều có đầu ra và minh chứng.	Bảng 6.1

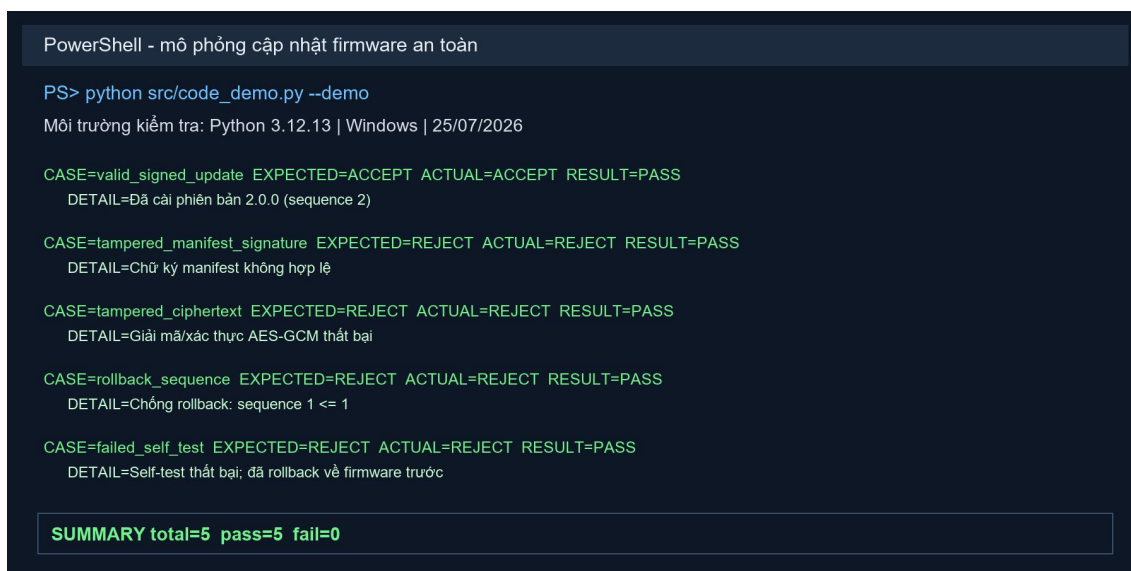
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường và chạy mô phỏng

Repository được lấy từ nhánh main tại commit nêu trong Chương 1. Môi trường rà soát dùng Windows và Python 3.12.13. Để tái lập theo cấu hình dự án, người dùng tạo môi trường ảo, cài `requirements.txt` và chạy `python src/code\_demo.py --demo`. Chương trình tự tạo gói, chạy năm kịch bản, ghi log và CSV.

Bảng 4.1. Lệnh tạo môi trường và chạy mô phỏng.

```
python -m venv .venv
.venv\Scripts\activate
python -m pip install -r requirements.txt
python src\code_demo.py --demo
```



```
PowerShell - mô phỏng cập nhật firmware an toàn

PS> python src/code_demo.py --demo
Môi trường kiểm tra: Python 3.12.13 | Windows | 25/07/2026

CASE=valid_signed_update EXPECTED=ACCEPT ACTUAL=ACCEPT RESULT=PASS
DETAIL=Đã cài phiên bản 2.0.0 (sequence 2)

CASE=tampered_manifest_signature EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
DETAIL=Chữ ký manifest không hợp lệ

CASE=tampered_ciphertext EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
DETAIL=Giải mã/xác thực AES-GCM thất bại

CASE=rollback_sequence EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
DETAIL=Chống rollback: sequence 1 <= 1

CASE=failed_self_test EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
DETAIL=Self-test thất bại; đã rollback về firmware trước

SUMMARY total=5 pass=5 fail=0
```

Hình 4.1. Kết quả chạy mô phỏng cục bộ ngày 25/07/2026; dữ liệu hiển thị được trích nguyên từ log do chương trình tạo.

4.2. Thành phần sản phẩm và cấu trúc repository

Bảng 4.2. Cấu trúc repository của sản phẩm.

```
n20-secure-firmware-update-iot/
├─ configs/security_policy.json
├─ data/firmware_v1.bin, firmware_v2.bin, firmware_v3_bad.bin
├─ src/code_demo.py, src/README_KEYS.md
├─ results/manifest_v2.json, signed_manifest_v2.json
├─ results/logs/secure_update_demo.log, results/test_matrix.csv
├─ update_so_do_hinh_anh/
└─ report/
```

Bảng 4.3. Thành phần sản phẩm và minh chứng.

Thành phần	Chức năng	Minh chứng
security_policy.json	Cố định target, giới hạn 4 MiB, thuật toán và yêu cầu rollback.	configs/
code_demo.py	Đóng gói, ký, mã hóa, xác minh, staging, self-test và test runner.	src/
manifest/chữ ký	Mô tả và xác thực gói v2.	results/*.json
log/ma trận	Ghi actual, expected, PASS/FAIL và lý do.	results/logs/, test_matrix.csv
sơ đồ	Mô tả luồng khóa, dữ liệu và OTA.	update_so_do_hinh_anh/
báo cáo	Gói trình bày và nộp bài.	report/

4.3. Kịch bản kiểm thử

Bảng 4.4. Các kịch bản kiểm thử.

ID	Mô tả/đầu vào	Thao tác	Kỳ vọng	Kiểm soát
TC-01	Firmware v2 và manifest hợp lệ.	Chạy quy trình đầy đủ.	ACCEPT	Toàn chuỗi
TC-02	Sửa một trường manifest sau khi ký.	Xác minh RSA-PSS.	REJECT	Xác thực nguồn
TC-03	Lật byte ciphertext.	Xác thực AES-GCM.	REJECT	Toàn vẹn payload
TC-04	Gói v1 có sequence 1 khi current=1.	So sánh sequence.	REJECT	Chống rollback
TC-05	v3_bad có chữ ký hợp lệ nhưng self-test lỗi.	Ghi staging, chạy self-test.	REJECT + rollback	Phục hồi

4.4. Kết quả và đối chiếu tiêu chí

Bảng 4.5. Kết quả kiểm thử và đối chiếu kỳ vọng.

Ca	Kỳ vọng	Thực tế	Kết quả	Chi tiết log
TC-01	ACCEPT	ACCEPT	PASS	Đã cài 2.0.0 (sequence 2)
TC-02	REJECT	REJECT	PASS	Chữ ký manifest không hợp lệ
TC-03	REJECT	REJECT	PASS	Xác thực AES-GCM thất bại
TC-04	REJECT	REJECT	PASS	sequence 1 <= 1
TC-05	REJECT + rollback	REJECT + rollback	PASS	Self-test lỗi; khôi phục bản trước

Kết quả ngày 25/07/2026 là 5/5 PASS, đúng ngưỡng ở Mục 3.5. TC-02 cho thấy hash đơn lẻ không xác thực nhà phát hành; TC-03 chứng minh AEAD phát hiện payload bị sửa; TC-04 cho thấy chữ ký hợp lệ không đồng nghĩa gói là mới; TC-05 cho thấy xác thực mật mã không thay thế kiểm thử khả năng hoạt động. Log đầy đủ được lưu tại `results/logs/secure\_update\_demo.log`.

4.5. Script tổng hợp kết quả

`src/code\_demo.py` vừa là prototype vừa là script báo cáo. Đầu vào là policy và firmware giả lập; đầu ra là manifest, chữ ký, khóa công khai demo, log và `test\_matrix.csv`. Hàm test runner trả mã thoát khác 0 nếu có ca FAIL, nhờ đó có thể đưa vào CI sau này. Trích xuất 6 dòng cuối của lần chạy:

Bảng 4.6. Trích xuất log của năm ca kiểm thử.

CASE=valid_signed_update EXPECTED=ACCEPT ACTUAL=ACCEPT RESULT=PASS CASE=tampered_manifest_signature EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS CASE=tampered_ciphertext EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS CASE=rollback_sequence EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS CASE=failed_self_test EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS SUMMARY total=5 pass=5 fail=0
--

4.6. Thảo luận và giới hạn

4.6.1. Đối chiếu mục tiêu. MT-02, MT-03 và MT-04 được chứng minh trực tiếp bằng code, policy, năm ca kiểm thử, log và CSV. MT-01 được hoàn thiện trong Chương 5. Mô hình đạt yêu cầu học phần vì có thể chạy lại, có cả ca thành công và thất bại, và giải thích được mỗi quyết định.

4.6.2. Giới hạn mô phỏng. Kết quả chỉ xác nhận logic prototype trên máy tính, không phải chứng nhận an toàn sản xuất. Báo cáo không tuyên bố đã chạy Wokwi hay ESP32 thật. Chưa đo độ trễ, RAM, năng lượng; chưa kiểm thử mất điện, lỗi flash, parser fuzzing hoặc tấn công side-channel. Các khoảng trống này được giữ rõ để tránh suy rộng vượt quá bằng chứng.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và yêu cầu CIA

Bảng 5.1. Tài sản và yêu cầu bảo mật CIA.

Tài sản	Giá trị/chủ thể	C	I	A	Kiểm soát chính
Khóa riêng ký	Quyền phát hành / publisher	Rất cao	Rất cao	Cao	HSM, phân quyền, rotate/revoke
Khóa công khai gốc	Root of trust / thiết bị	Thấp	Rất cao	Cao	eFuse/secure element
Firmware	Mã thực thi / thiết bị	Cao	Rất cao	Rất cao	AES-GCM, SHA-256, ký manifest
Manifest	Quy tắc cài đặt	Thấp	Rất cao	Cao	RSA-PSS
Sequence/trạng thái	Chống rollback	Thấp	Rất cao	Cao	Lưu bền vững, cập nhật nguyên tử
Bản đang chạy	Khả năng vận hành	Tùy loại	Cao	Rất cao	A/B, self-test, rollback

5.2. Phân tích STRIDE gắn với hệ thống

Bảng 5.2. Phân tích STRIDE cho chuỗi cập nhật OTA.

STRIDE	Mối đe dọa trong chuỗi OTA	Tài sản	Kiểm soát/minh chứng
S – Spoofing	Giả mạo nhà phát hành.	Firmware, manifest	RSA-PSS; TC-02
T – Tampering	Sửa manifest hoặc ciphertext.	Manifest, payload	Chữ ký, AES-GCM, SHA-256; TC-02/03
R – Repudiation	Phủ nhận việc phát hành/cài đặt do log yếu.	Nhật ký cập nhật	Commit, manifest ký, log; cần log bất biến khi triển khai
I – Information disclosure	Lộ firmware hoặc khóa ký.	Firmware, khóa	AES-GCM; HSM/ACL; không commit khóa riêng
D – Denial of service	Gói lỗi làm thiết bị không boot hoặc cạn tài nguyên.	Bản đang chạy	Giới hạn size, staging, self-test, rollback; TC-05
E – Elevation of privilege	Cài bản giả/cũ để chiếm quyền.	Toàn thiết bị	Chữ ký, sequence, target; TC-02/04

5.3. Ma trận rủi ro 5×5 và ưu tiên

Thang điểm: Khả năng (K) và Tác động (T) từ 1 đến 5; Điểm = $K \times T$. Phân loại 1–4 Thấp, 5–9 Trung bình, 10–16 Cao, 17–25 Nghiêm trọng. Ma trận sau đặt ID rủi ro vào đúng tọa độ ban đầu.

Bảng 5.3. Ma trận rủi ro 5×5 .

T \ K	1	2	3	4	5
5			R6	R1, R2	
4			R4	R3, R5	
3					
2					
1					

Bảng 5.4. Danh sách và mức ưu tiên rủi ro.

ID	Rủi ro	K	T	Điểm/mức	Ưu tiên
R1	Firmware giả mạo	4	5	20 – Nghiêm trọng	1
R2	Payload bị sửa	4	5	20 – Nghiêm trọng	1
R3	Rollback/phát lại	4	4	16 – Cao	2
R4	Cài sai target	3	4	12 – Cao	3
R5	Bản mới không boot	4	4	16 – Cao	2
R6	Lộ khóa ký	3	5	15 – Cao	1

5.4. Kiểm soát theo rủi ro ưu tiên

Bảng 5.5. Kiểm soát và rủi ro còn lại.

Rủi ro	Kiểm soát đầu-cuối	Kiểm soát kênh/vận hành	Còn lại
R1/R2	Ký manifest RSA-PSS; AES-GCM; SHA-256; fail closed.	HTTPS/mTLS, giới hạn size, giám sát kho.	Lộ khóa ký, lỗi parser
R3	Sequence đơn điệu nằm trong manifest đã ký.	Lưu trạng thái nguyên tử; chống mất điện.	Hỏng/rollback bộ đếm
R4	Target/model nằm trong phần đã ký.	Quản lý inventory thiết bị.	Sai mapping sản xuất
R5	Staging, self-test, xác nhận ảnh, rollback.	Phân vùng A/B, watchdog, giới hạn số lần boot.	Lỗi bootloader/flash
R6	Chuỗi tin cậy hỗ trợ rotate/revoke.	HSM, ACL tối thiểu, phê duyệt kép, audit log.	Nội gián/side-channel

HTTPS/mTLS không thay thế chữ ký firmware: nó bảo vệ một đoạn kênh tại thời điểm truyền, còn chữ ký và metadata đã ký bảo vệ đầu-cuối trong suốt vòng đời gói. Tương tự, SHA-256 chỉ phát hiện thay đổi khi giá trị hash được neo trong dữ liệu đã xác thực.

5.5. Rủi ro còn lại và điều kiện xem xét lại

Prototype chấp nhận các rủi ro còn lại: chưa có root of trust phần cứng, HSM, lưu sequence chống mất điện, bootloader thật, benchmark MCU và kiểm thử side-channel. Các rủi ro phải được xem xét lại khi chuyển sang ESP32/MCU thật; thay đổi thuật toán hoặc định dạng manifest; tăng kích thước firmware; thêm nhà phát hành; phát hiện lộ khóa; hoặc triển khai qua Internet. Trước sản xuất cần threat model lại, kiểm thử mất điện/fuzzing, đánh giá độc lập và diễn tập rotate/revoke khóa.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận theo mục tiêu

Bảng 6.1. Kết quả thực hiện theo mục tiêu.

Mục tiêu	Kết quả	Mức đạt	Minh chứng
MT-01	Xác định tài sản, STRIDE và 6 rủi ro trên ma trận 5×5.	Đạt	Chương 5
MT-02	Có manifest, SHA-256, RSA-PSS, AES-256-GCM và RSA-OAEP.	Đạt trong mô phỏng	src/, configs/, results/
MT-03	Có target, sequence, staging, self-test và rollback.	Đạt trong mô phỏng	TC-04, TC-05
MT-04	Repo có hướng dẫn, code, log, CSV, sơ đồ; chạy lại 5/5 PASS.	Đạt	Commit a8febb2

Kết quả chứng minh nguyên tắc thiết kế chứ không chứng minh một thiết bị thương mại đã an toàn. Đóng góp chính là mô hình nhỏ, minh bạch và có thể chạy lại, trong đó mỗi quyết định ACCEPT/REJECT được nối với một kiểm soát và một rủi ro cụ thể.

6.2. Hạn chế

Hạn chế lớn nhất là chưa triển khai trên MCU thật và chưa tích hợp bootloader/Secure Boot. Khóa demo được tạo trong phần mềm; trạng thái sequence chưa được bảo vệ bằng phần cứng; tập test chỉ có năm ca; chưa đo hiệu năng/tài nguyên và chưa kiểm tra mất điện, lỗi flash, fuzzing hay side-channel. Lịch sử GitHub có nhiều commit cùng ngày 18/07/2026 nên chỉ phản ánh các bước kỹ thuật, không đại diện cho sáu tuần làm việc tách biệt.

6.3. Hướng phát triển

- + Chuyển prototype sang ESP32/ESP-IDF hoặc Wokwi, dùng phân vùng A/B, Secure Boot, flash encryption và eFuse anti-rollback.
- + Đưa khóa ký vào HSM; bổ sung quy trình cấp, xoay vòng, thu hồi và nhật ký phê duyệt.
- + Thêm HTTPS/mTLS, chứng chỉ thiết bị và chính sách phân phối theo nhóm/target.
- + Kiểm thử mất điện, lỗi flash, parser fuzzing; đo thời gian, RAM, kích thước và năng lượng trên MCU.
- + Tích hợp CI để chạy test tự động và lưu artifact/log theo từng commit phát hành.

TÀI LIỆU THAM KHẢO

- [1] B. Moran et al., “A Firmware Update Architecture for Internet of Things Devices,” RFC 9019, IETF, 2021, <https://datatracker.ietf.org/doc/html/rfc9019>. Truy cập 28/07/2026. Dùng cho kiến trúc và vai trò.
- [2] B. Moran et al., “A Manifest Information Model for Firmware Updates in IoT Devices,” RFC 9124, IETF, 2022, <https://datatracker.ietf.org/doc/html/rfc9124>. Truy cập 28/07/2026. Dùng cho manifest và điều kiện.
- [3] NIST, “Platform Firmware Resiliency Guidelines,” SP 800-193, 2018, <https://csrc.nist.gov/pubs/sp/800/193/final>. Truy cập 28/07/2026. Dùng cho protect–detect–recover.
- [4] K. Moriarty et al., “PKCS #1: RSA Cryptography Specifications Version 2.2,” RFC 8017, IETF, 2016, <https://datatracker.ietf.org/doc/html/rfc8017>. Truy cập 28/07/2026. Dùng cho RSA-PSS/OAEP.
- [5] NIST, “Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode,” SP 800-38D, 2007, <https://csrc.nist.gov/pubs/sp/800/38/d/final>. Truy cập 28/07/2026. Dùng cho AES-GCM.
- [6] NIST, “Secure Hash Standard,” FIPS 180-4, <https://csrc.nist.gov/pubs/fips/180-4/upd1/final>. Truy cập 28/07/2026. Dùng cho SHA-256.
- [7] Espressif Systems, “Over The Air Updates (OTA), ESP-IDF v5.4.2,” <https://docs.espressif.com/projects/esp-idf/en/v5.4.2/esp32/api-reference/system/ota.html>. Truy cập 28/07/2026. Dùng cho phân vùng và rollback.
- [8] OWASP, “IoT Security Verification Standard,” <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. Truy cập 28/07/2026. Dùng cho yêu cầu cập nhật và bảo vệ khóa.
- [9] Trần Thị Hà Vy, “n20-secure-firmware-update-iot,” commit 933dc849b40244fea8a7bd68917f2cc10667cdbf, <https://github.com/hv6z/n20-secure-firmware-update-iot>. Truy cập 29/07/2026. Dùng cho toàn bộ code, cấu hình và minh chứng thực nghiệm.

PHỤ LỤC A. PHẦN A – CHECKLIST VÀ PHIẾU TIẾN ĐỘ

Phụ lục này giữ lại nội dung lịch sử đã điền trong báo cáo Tuần 02. Trạng thái phần trăm là trạng thái tại thời điểm Tuần 02, không phải trạng thái của bản cuối kỳ.

A.1. Checklist nhanh trước khi viết – Tuần 02

Bảng A.1. Checklist nhanh trước khi viết - Tuần 02.

Nội dung	Yêu cầu cuối Tuần 02	Trạng thái	Minh chứng
Góp ý lần 1	Đã rà soát mục tiêu, phạm vi, đầu ra và cấu trúc theo đúng mã đề tài 20.	☒ Đạt ☐ Bổ sung	Chương 1 và bảng đối chiếu mục tiêu
Chương 1	Đã viết đủ các mục 1.1-1.6.	☒ Đạt ☐ Bổ sung	Chương 1 của tài liệu này
Chương 2	Đã viết bản nháp khoảng 60-70%, tập trung firmware, OTA, khóa và chuỗi tin cậy.	☒ Đạt ☐ Bổ sung	Các mục 2.1-2.6
Tài liệu	Có 5 nguồn chính và các nguồn mở rộng trong thư mục references.	☒ Đạt ☐ Bổ sung	Bảng nguồn tại mục 2.4
Repo	Có README, mã nguồn, cấu hình, dữ liệu giả lập và thư mục kết quả.	☒ Đạt ☐ Bổ sung	Repo GitHub/README.md
Chuẩn bị Buổi 03	Có dàn ý Chương 3, sơ đồ OTA an toàn và kế hoạch kiểm thử.	☒ Đạt ☐ Bổ sung	Chương 3 và update_so_do_hinh_anh/

A.2. Góp ý và cách xử lý – Tuần 02

Bảng A.2. Góp ý và cách xử lý - Tuần 02.

Góp ý	Cách đã xử lý	Vị trí trong bản thảo	Trạng thái
Chưa có góp ý chi tiết bằng văn bản từ giảng viên.	Tự rà soát theo yêu cầu Tuần 02 và mã đề tài 20.	Toàn bộ Chương 1-2	Chờ giảng viên bổ sung

Góp ý	Cách đã xử lý	Vị trí trong bản thảo	Trạng thái
Nội dung tự rà soát: cần chứng minh chữ ký manifest.	Bổ sung ca `tampered_manifest_signature` và manifest có chữ ký.	Repo: src/ và results/	Đã xử lý
Nội dung tự rà soát: sơ đồ luồng cần rõ biên tin cậy.	Số hóa quy trình phát hành-máy chủ-thiết bị và các bước reject.	update_so_do_hinh_anh/	Đã xử lý
Cần bổ sung góp ý từ giảng viên			Chờ bổ sung

A.3. Minh chứng đã khai báo – Tuần 02

Bảng A.3. Minh chứng đã khai báo - Tuần 02.

ID	Loại	Tên file/link/commit	Nội dung chứng minh	Ngày
MC-01	Repo/README	https://github.com/hv6z/n20-secure-firmware-update-iot	Cấu trúc, cách chạy, nguồn và giới hạn an toàn	18/07/2026
MC-02	Mã nguồn	src/code_demo.py	Tạo gói, xác minh chữ ký, giải mã,	18/07/2026

ID	Loại	Tên file/link/commit	Nội dung chứng minh	Ngày
			anti- rollback và self-test	
MC-03	Log/Bảng	results/logs/secure_update_demo.log results/test_matrix.csv	Năm ca kiểm thử đều đạt kỳ vọng	18/07/2026
MC-04	Manifest	results/signed_manifest_v2.json	Manifest và chữ ký dùng để kiểm tra nguồn gốc	18/07/2026
MC-05	Sơ đồ	update_so_do_hinh_anh/so_do_ota_an_toan.png	Luồng OTA an toàn và các điểm từ chối	18/07/2026

A.4. Thông tin chung của phiếu tiến độ

Bảng A.4. Thông tin chung của phiếu tiến độ.

Mã SV	231A010297	Họ và tên	Trần Thị Hà Vy
Lớp	253INT441001	Tuần báo cáo	Tuần 02
Mã đề tài	20	Tên đề tài	Cập nhật firmware an toàn cho thiết bị IoT
Link GitHub/repo	https://github.com/hv6z/n20-secure-firmware-update-iot	Link minh chứng	Repo GitHub và thư mục results/
Ngày cập nhật	18/07/2026	Mức tự đánh giá	☒ Đúng tiến độ ☐ Cần hỗ trợ ☐ Nguy cơ chậm
Email/SĐT liên hệ	havytran1111@gmail.com	Nhóm/cá nhân	☒ Cá nhân ☐ Nhóm

A.5. Checklist tiến độ Tuần 02

Bảng A.5. Checklist tiến độ Tuần 02.

STT	Nội dung cần hoàn thành	Trạng thái	Ghi chú/minh chứng
1	Đã tạo repo GitHub/thư mục làm việc và đặt tên đúng đề tài.	☒ Xong ☐ Đang làm ☐ Chưa làm	Repo đúng tên, có README và cấu trúc src/configs/data/results/report.
2	Đã viết đề cương 1-2 trang: lý do chọn đề tài, mục tiêu, phạm vi, sản phẩm dự kiến.	☒ Xong ☐ Đang làm ☐ Chưa làm	Chương 1 hoàn chỉnh; đã xác định lý do, vấn đề, mục tiêu, phạm vi và đầu ra.
3	Đã thu thập tối thiểu 5 tài liệu tham khảo, trong đó có ít nhất 1 repo/tool GitHub liên quan.	☒ Xong ☐ Đang làm ☐ Chưa làm	Có ít nhất 5 nguồn chính: ESP-IDF, OWASP ISVS, FSTM, IETF SUIT và IoTGoat.
4	Đã xác định công cụ hoặc phương pháp chính sẽ dùng: lab, checklist, STRIDE, OWASP, demo, code hoặc	☒ Xong ☐ Đang làm ☐ Chưa làm	Phương pháp: nghiên cứu tài liệu, mô hình luồng, demo Python, ca thử dương/âm và đánh giá rủi ro.

STT	Nội dung cần hoàn thành	Trạng thái	Ghi chú/minh chứng
	phân tích case study.		
5	Đã có kế hoạch Tuần 03 rõ ràng: chạy thử, thu log/ảnh minh chứng, hoàn thiện bảng rủi ro hoặc demo.	☒ Xong ☐ Đang làm ☐ Chưa làm	Đã có dàn ý Chương 3, sơ đồ OTA và kế hoạch bổ sung test plan/ma trận rủi ro.

A.6. Nội dung đã thực hiện trong tuần

Bảng A.6. Nội dung đã thực hiện trong tuần.

ST T	Công việc	Kết quả hiện tại	Minh chứng/link/file	Tỷ lệ hoàn thành
1	Viết Chương 1	Hoàn thành các mục 1.1-1.6 và bảng đối chiếu mục tiêu.	Báo cáo Tuần 02 - Chương 1	100%
2	Viết bản nháp Chương 2	Hoàn thành khoảng 60-70% về kiến trúc, mật mã, firmware/OTA và nguồn liên quan.	Báo cáo Tuần 02 - Chương 2	70%
3	Thu thập và phân loại nguồn	Có 5 nguồn chính, ghi rõ URL, phiên bản, phần sử dụng và ngày truy cập.	Bảng nguồn mục 2.4; references/link_nguon.md	100%
4	Xây dựng sơ đồ và threat model	Có kiến trúc ba vùng, biên tin cậy và luồng xác minh trước khi cài.	update_so_do_hinh_anh/so_do_ota_an_toan.png	80%
5	Chuẩn bị	Có mã Python,	src/code_demo.py; results/	100%

ST T	Công việc	Kết quả hiện tại	Minh chứng/link/file	Tỷ lệ hoàn thành
	prototype và minh chứng	manifest, log và ma trận 5 ca kiểm thử để phát triển ở các tuần sau.		

A.7. Khó khăn/rủi ro đang gặp

Bảng A.7. Khó khăn và rủi ro đang gặp.

Vấn đề	Ảnh hưởng tới tiến độ	Hỗ trợ cần từ GV/bạn học
Demo hiện chỉ chạy bằng Python, chưa có ESP32/bootloader/flash A-B thật.	Chưa thể kết luận về RAM, thời gian xác minh và khả năng chịu mất điện trên phần cứng.	Nhờ giảng viên xác nhận phạm vi mô phỏng hoặc yêu cầu bổ sung phần cứng.
Quản lý vòng đời khóa chưa được triển khai bằng HSM/secure element.	Chưa chứng minh rotation, revocation và bảo vệ khóa ở mức sản xuất.	Xin góp ý mức độ cần trình bày trong Chương 5.
Chưa có góp ý chi tiết cho bản Tuần 02.	Có thể phải điều chỉnh bố cục hoặc độ sâu Chương 2 sau khi nhận xét.	Nhờ giảng viên đánh dấu các mục cần ưu tiên sửa.

A.8. Kế hoạch Tuần 03

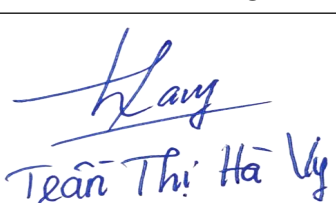
Bảng A.8. Kế hoạch Tuần 03.

Công việc Tuần 03	Sản phẩm dự kiến	Thời hạn	Ghi chú
Hoàn thiện Chương 2 và chuẩn hóa trích dẫn	Chương 2 hoàn chỉnh và bảng nguồn đã rà soát	22/07/2026	Bổ sung theo góp ý
Viết Chương 3	Sơ đồ kiến trúc, threat	24/07/2026	Dùng dữ liệu giả lập

Công việc Tuần 03	Sản phẩm dự kiến	Thời hạn	Ghi chú
- phương pháp và thiết kế	model và mô tả quy trình		
Hoàn thiện test plan và tiêu chí đánh giá	Bảng ca thử chấp nhận/từ chối và tiêu chí PASS/FAIL	28/07/2026	Gắn với MT-01 đến MT-04
Cập nhật repo và minh chứng	Commit, README, ảnh/log và bảng rủi ro bản đầu	28/07/2026	1cbea67ac1b2c3e65d55d7ef9085f2bd6a235276

A.9. Tự đánh giá của sinh viên

Bảng A.9. Tự đánh giá của sinh viên.

Tiến độ tự đánh giá	☐ 0-25% ☒ 26-50% ☐ 51-75% ☐ 76-100%
Mức độ hiểu đề tài	☐ Chưa rõ ☐ Cơ bản ☒ Khá rõ ☐ Rất rõ
Cam kết tuần tới	Hoàn thành Chương 2 và Chương 3 đúng kế hoạch; cập nhật repo, test plan và minh chứng trước 25/07/2026.
Chữ ký/tên sinh viên	 Trần Thị Hà Vy

A.10. Tổng hợp tiến độ Tuần 01-06 theo minh chứng thực tế

Bảng dưới đây tổng hợp theo lịch sử repository và nội dung đã tích lũy. Tuần không có bản nộp riêng được ghi đúng thực tế, không tạo minh chứng hồi tố.

Bảng A.10. Tổng hợp tiến độ các tuần theo minh chứng thực tế.

Tuần	Trạng thái thực tế	Nội dung tích lũy	Minh chứng
Tuần 01	Đã thực hiện	Khởi tạo repository, README và cấu trúc ban đầu.	Commits 29ba97d, 9499a6d; README.md; configs/.
Tuần 02	Đã thực hiện	Hoàn thiện Chương 1-2; policy, firmware giả lập, code demo và 5 ca kiểm thử.	Commits 8e22f6e, 73aa4cf, 9dac557, 22b6697; results/.
Tuần 03	Không nộp bản riêng	Nội dung Chương 2-3 được hoàn thiện tích lũy trong bản cuối; không khai đã nộp Tuần 03.	Chương 2-3; Bảng 3.1-3.3; commit a8febb2.
Tuần 04	Tích lũy trong bản cuối	Hoàn thiện Chương 4: môi trường, sản phẩm, kịch bản và kết quả kiểm thử.	Chương 4; results/test_matrix.csv; commit a8febb2.
Tuần 05	Tích lũy trong bản cuối	Hoàn thiện Chương 5-6: CIA, STRIDE, ma trận rủi ro, kết luận và hướng phát triển.	Chương 5-6; commit a8febb2.
Tuần 06	Hoàn thành	Rà soát mẫu, nguồn, phụ lục; hoàn thiện DOCX/PDF và repository công khai.	Commit 1cbea67; report/*.docx, report/*.pdf.

PHỤ LỤC B. REPOSITORY, COMMIT VÀ GÓI NỘP

Repository: <https://github.com/hv6z/n20-secure-firmware-update-iot>

Commit nền dùng đối chiếu trước khi tải báo cáo cuối: 933dc849b40244fea8a7bd68917f2cc10667cdbf (29/07/2026).

Bảng B.1. Commit dùng để đối chiếu bộ nộp.

Commit	Ngày	Nội dung
933dc849b40244fea8a7bd68917f2cc10667cdbf	29/07/2026	Commit nền dùng để đối chiếu nội dung, mã nguồn và minh chứng trước khi tải báo cáo cuối.

PHỤ LỤC C. CHECKLIST TRƯỚC KHI IN VÀ NỘP

Bảng C.1. Checklist trước khi in và nộp.

STT	Nội dung kiểm tra	Trạng thái
1	Đúng tên file MSSV_HoTen_DeTai20_TieuLuan_CuoiKy (.docx và .pdf).	☒ Đạt
2	Một file có Chương 1–6, tài liệu tham khảo và phụ lục tiến độ.	☒ Đạt
3	Đã xóa hướng dẫn mẫu, phụ lục 50 đề tài và chỗ giữ chỗ.	☒ Đạt
4	Mục lục tự động, tiêu đề dùng Heading 1/2.	☒ Đạt
5	Hình/bảng có số, tên, nguồn và được phân tích.	☒ Đạt
6	Kết quả Chương 4 khớp log/CSV tại commit đã khai.	☒ Đạt
7	Có ≥ 5 nguồn, URL sạch, ngày truy cập và phân sử dụng.	☒ Đạt
8	Không có secret, token, mật khẩu hoặc khóa riêng triển khai.	☒ Đạt
9	Đã ghi rõ mô phỏng local, không tuyên bố chạy phần cứng thật.	☒ Đạt
10	Cần cập nhật README và tải DOCX/PDF cuối lên GitHub trước nộp.	☐ Sinh viên thực hiện
11	Mở PDF kiểm tra lần cuối và ký tên bản in.	☐ Sinh viên thực hiện